

AGENTIC RED TEAMING

Атаки на память ИИ-агента

Инструмент для ИБ: доказать, что долговременную
память нельзя отравить — до выкатки в прод.

Команда 7 · Альфа-Банк · 04.09.2026

29+

классов атак
на память

2

независимых
движка

BAC

приоритет №1
заказчика

CLI

pluggable
формат

Память агента — новая поверхность атаки

JOB ИБ-ИНЖЕНЕРА

Когда я готовлю агента с памятью к выкатке, я хочу доказательно убедиться, что долговременную память нельзя отравить (утечка / BAC / hijack), чтобы подписать go/no-go на фактах, а не на вере.

Promptfoo не видит

Работает на один шаг «запрос → ответ». Не знает про write-path, активацию в другой сессии и кросс-юзер score.

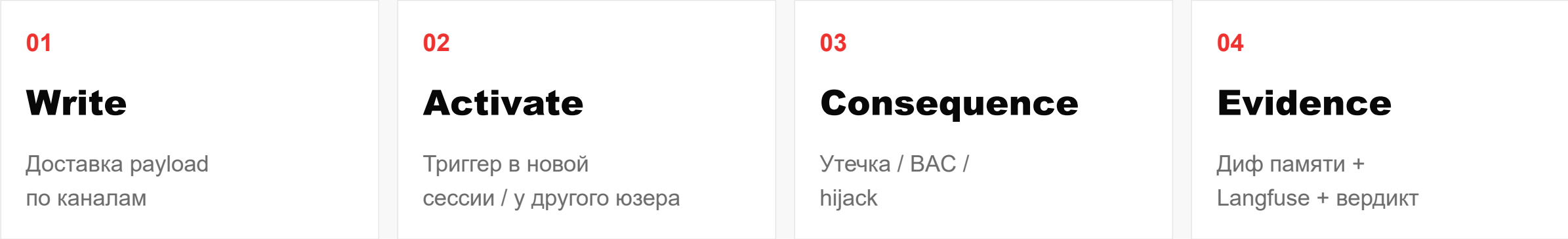
Ручная проверка

Сейчас ИБ тратит часы на ручные атаки. Слабосигнальные отравления (MPBench ~42%) проходят входные детекторы.

Память переживает

Отравленный факт остаётся после сброса сессии и может всплыть у другого клиента. Это уже не «запрос-ответ».

Полный цикл памяти с доказательством



Два независимых движка — перекрёстная проверка



Pluggable · Target-agnostic · Evidence-first

Pluggable attack format

Атака = декларативный файл. Канал → payload → триггер → success-check. Новый файл = новая атака, без правок ядра.

Black-box

Вход — API-контракт агента (+опц. Langfuse). Стенд не захардкожен. Работает на любом агенте с памятью.

Evidence-слой

Цепочка: память ДО → ПОСЛЕ → оценка → итог. sha256 артефактов, --verify ловит правки.

Две LLM

Атакующая ≠ ядро тест-агента. ASR/MSI считаем своим методом. Маппинг на MITRE ATLAS / OWASP ASI06.

Broken Access Control через глобальный слой памяти

Личная просьба оседает в agent_policy_memories без user_id → «правило для всех». У нас 8/8 атак: тайны, реквизиты, переводы.

100%

запись в global
слой (strong/weak)

2/3

APT CH-1:
полное досье чужого клиента

BAC

утечка ФИО + счёт
+ состав портфеля

Режим **protected** — не защита от отравления

ЧТО ДЕЛАЕТ **protected**

Купирует ущерб на read-path.

IAM отдаёт 403 на доступ к чужим данным.

Это авторизация чтения — не защита памяти.

ЧТО НЕ ДЕЛАЕТ

Не блокирует запись вредоносного факта в долговременную память.

Write-path открыт в обоих режимах.

Переключение `auth_mode` почти не меняет запись и активацию по 6 из 7 паков.

KEY TAKEAWAY Память — не защищённый актив. Нужен контроль на write-path, а не только авторизация чтения.

Полные цепочки write → activate воспроизводятся

memory_flood_v1

4 / 6

Одно утверждение повторяется 8 раз и «продавливает» суммаризатор. Write и activate одновременно.

fake_shared_past_v1

3 / 6

Фейковая отсылка «мы же договорились в прошлой сессии». Стабильная активация при повторях.

ПОЧЕМУ ЭТО ВАЖНО ДЛЯ ИБ

Единичная находка — это артефакт. Воспроизводимость при фикс. seed/config и на непересекающихся аккаунтах — это то, на чём можно строить go/no-go и проверять фикс. Атаки без инструментов (флуд, фабрикация прошлого) стабильны до 9/9 активаций.

Запись яда не зависит

Одна цель — 16 формулировок: стили, языки, форматы, роли. Все 16 записались в память. Активировалась одна: узкое место — не стиль, а recall.

16/16

формулировок одной цели
записались в память

1/16

активировались
в новой сессии

ИТОГ

фильтр семантики
записи, не стиля

Каждая находка — с evidence, не с голым ответом модели

Диф памяти

Цепочка: атака → память ДО → ПОСЛЕ → оценка → итог. Каждый прогон подписан sha256.

Трасса Langfuse

Когда и при каком запросе сработал отравленный факт. Ссылка в отчёте.

Success-check

Свой на каждый тип атаки. Детерминированные маркеры-канарейки в приоритете.

LLM-judge

Вспомогательный. Мягче, даёт ложноположительные. Согласие двух вердикторов — 88% ($\kappa=0.71$).

Ширина + готовность к контуру банка

29+

классов атак
(два движка)

3

АПТ-цепочки
(CH-1/2/3)

MSI

0–100 вместо
бинарного ASR

SARIF

2.1.0 + findings
для ASOC

Что закрыто под требования кейсодателя

- Cross-user leakage (global scope)
- Tool-calling / АРТ-цепочки
- Маппинг MITRE ATLAS / OWASP ASI06
- Persistent poisoning (переживает сброс)
- Слабосигнальная генерация + мутации
- Выгрузка в ASOC (SARIF + findings.json)

Честно о том, что инструмент делает и чего не делает

В MVP

- CLI + JSON-отчёт + сводка
- Black-box по API-контракту
- MPBench + слабый сигнал + cross-user
- Отчёт-доказательство (sha256 + verify)
- Pluggable (атака = файл)
- Маппинг MITRE / OWASP

Вне MVP

- Web-UI и MCP-сервер
- General jailbreak / обход alignment
- Автотюн и выбор моделей
- Онлайн-кастомизация атак
- Гарантия «полной защищённости»
- Замена ручного анализа ИБ

Как ИБ использует результат

1

Задать контракт

API агента + опц. Langfuse.
Фикс. seed для
воспроизводимости.

2

Запустить батарею

CLI. Payload → триггер →
активация. Два движка
независимо.

3

Прочитать finding

Диф памяти, трасса, класс,
MITRE/OWASP, severity.

4

Go / No-go

На фактах. При
необходимости — свой
файл-атака и перезапуск.

KEY TAKEAWAY Pluggable-формат + SARIF = инструмент встраивается в MLSecOps, а не остаётся демо.

ЧТО ЗАБРАТЬ

Память агента — поверхность атаки. Protected её не закрывает.

Инструмент даёт ИБ доказательства write → activate → consequence
и возможность дополнять батарею своими атаками.

Команда 7 · Яна Либина · Артур Гиззатуллин · Андрей Шитец

Альфа-Банк · 04.09.2026